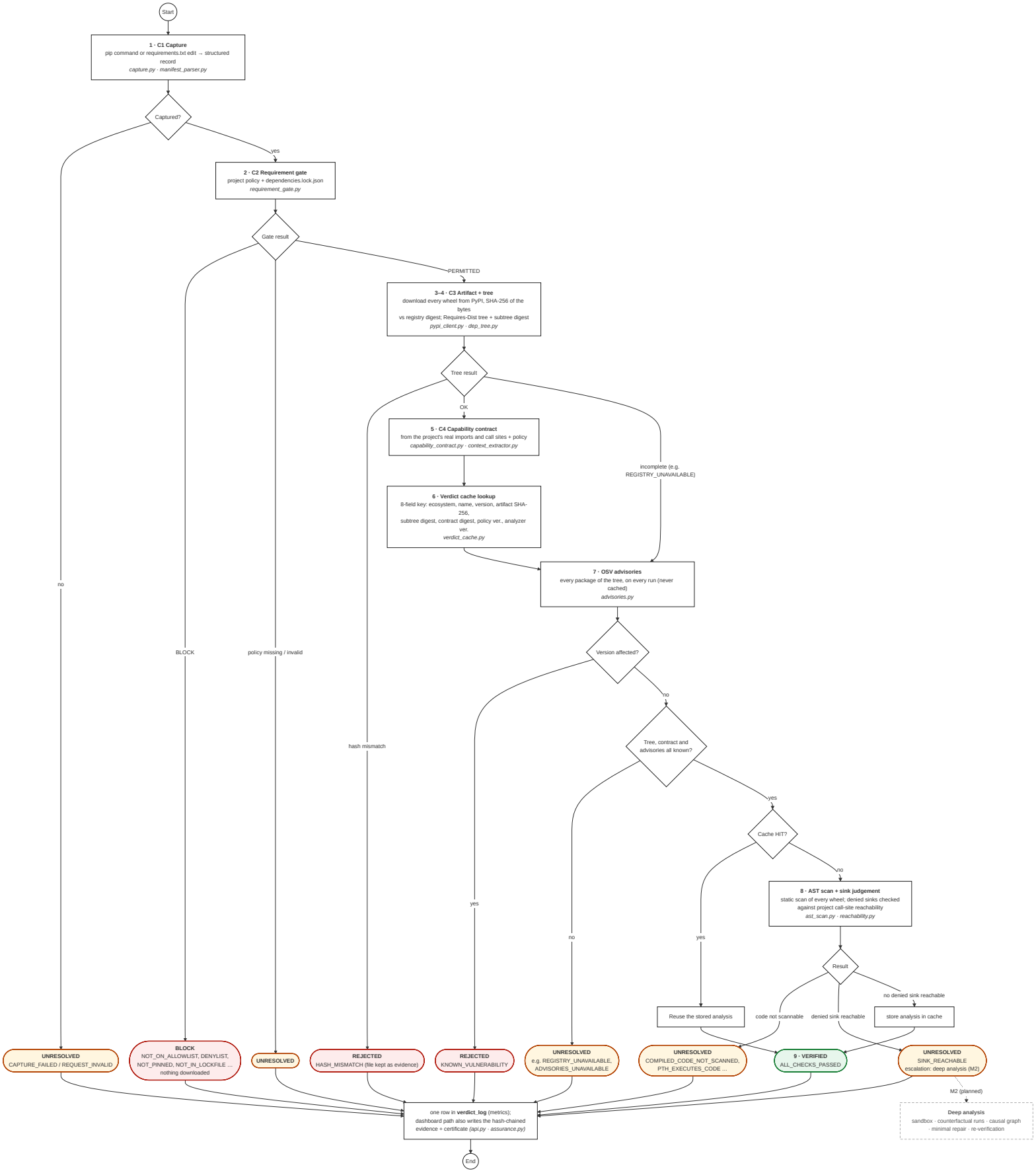

Start
1 · C1 Capture
pip command or requirements.txt edit → structured record
capture.py · manifest_parser.py
Captured?
no
yes
2 · C2 Requirement gate
project policy + dependencies.lock.json
requirement_gate.py
Gate result
BLOCK
policy missing / invalid
PERMITTED
3–4 · C3 Artifact + tree
download every wheel from PyPI, SHA-256 of the bytes
vs registry digest; Requires-Dist tree + subtree digest
pypi_client.py · dep_tree.py
Tree result
hash mismatch
OK
5 · C4 Capability contract
from the project's real imports and call sites + policy
capability_contract.py · context_extractor.py
6 · Verdict cache lookup
8-field key: ecosystem, name, version, artifact SHA-256,
subtree digest, contract digest, policy ver., analyzer ver.
verdict_cache.py
incomplete (e.g. REGISTRY_UNAVAILABLE)
7 · OSV advisories
every package of the tree, on every run (never cached)
advisories.py
Version affected?
yes
no
Tree, contract and advisories all known?
no
yes
Cache HIT?
yes
no
8 · AST scan + sink judgement
static scan of every wheel; denied sinks checked against project call-site reachability
ast_scan.py · reachability.py
Result
code not scannable
denied sink reachable
no denied sink reachable
Reuse the stored analysis
store analysis in cache
UNRESOLVED
CAPTURE_FAILED / REQUEST_INVALID
BLOCK
NOT_ON_ALLOWLIST, DENYLIST, NOT_PINNED, NOT_IN_LOCKFILE … nothing downloaded
UNRESOLVED
REJECTED
HASH_MISMATCH (file kept as evidence)
REJECTED
KNOWN_VULNERABILITY
UNRESOLVED
e.g. REGISTRY_UNAVAILABLE, ADVISORIES_UNAVAILABLE
UNRESOLVED
COMPILED_CODE_NOT_SCANNED, PTH_EXECUTES_CODE …
9 · VERIFIED
ALL_CHECKS_PASSED
UNRESOLVED
SINK_REACHABLE
escalation: deep analysis (M2)
M2 (planned)
Deep analysis
sandbox · counterfactual runs · causal graph · minimal repair · re-verification
one row in verdict_log (metrics);
dashboard path also writes the hash-chained evidence + certificate (api.py · assurance.py)
End